

Alert Tuning Report

Rule 5706 — False Positive Reduction

CyberShelter UAE Internship — Day 12 | Mohammed Farhan | 13 July 2026

Rule Tuned

Rule 5706 — "sshd: insecure connection attempt (scan)". Fires when an SSH client connects but disconnects before completing identification, commonly triggered by port scanners and vulnerability-scanning tools.

Original Behaviour (Before Tuning)

Rule 5706 fires at level 6 for any source IP, including the organisation's own internal admin/scanning range, generating a visible alert every time. Verified via wazuh-logtest against the exact trigger phrase ("Did not receive identification string from")

"Jul 13 19:05:00 ubuntuuser sshd[99999]: Did not receive identification string from 192.168.1.50"

```
Session Actions Edit View Help
fara@ubuntuuser:~$ docker exec -it single-node-wazuh.manager-1 /var/ossec/bin
/wazuh-logtest
Starting wazuh-logtest v4.9.0
Type one log per line

Jul 13 19:05:00 ubuntuuser sshd[99999]: Did not receive identification string
from 192.168.1.50
```

```
**Phase 1: Completed pre-decoding.
  full event: 'Jul 13 19:05:00 ubuntuuser sshd[99999]: Did not receive
identification string from 192.168.1.50'
  timestamp: 'Jul 13 19:05:00'
  hostname: 'ubuntuuser'
  program_name: 'sshd'

**Phase 2: Completed decoding.
  name: 'sshd'
  parent: 'sshd'
  srcip: '192.168.1.50'

**Phase 3: Completed filtering (rules).
  id: '5706'
  level: '6'
  description: 'sshd: insecure connection attempt (scan).'
  groups: '['syslog', 'sshd', 'recon']'
  firetimes: '1'
  gdpr: '['IV_35.7.d']'
  gpg13: '['4.12']'
  mail: 'False'
  mitre.id: '['T1021.004']'
  mitre.tactic: '['Lateral Movement']'
  mitre.technique: '['SSH']'
  nist_800_53: '['SI.4']'
  pci_dss: '['11.4']'
  tsc: '['CC6.1', 'CC6.8', 'CC7.2', 'CC7.3']'

**Alert to be generated.
```

Business Justification for the Exclusion

The organisation's internal security/admin team (192.168.1.0/24) routinely runs vulnerability scanning and network monitoring tools that generate this exact connection pattern against internal systems as part of legitimate, scheduled security operations. Without tuning, every scan cycle generates a full batch of level-6 alerts that provide no investigative value, since the source is known, authorised, and already accounted for. This directly contributes to analyst alert fatigue and increases the risk that a genuine external scan is overlooked amid repetitive internal noise.

This exclusion is documented here specifically to avoid an audit gap: without a recorded justification, a future investigator or auditor reviewing why traffic from 192.168.1.0/24 does not generate alerts would have no way to confirm this was a deliberate, reviewed decision rather than a misconfiguration or an attempt to conceal activity.

Exception Rule Deployed

- ```
<rule id="100207" level="0">
 <if_sid>5706</if_sid>
 <srcip>192.168.1.0/24</srcip>
 <description>sshd: insecure connection attempt (scan) -
 excluded admin range</description>
</rule>
```

### Design notes:

- if\_sid=5706 — the exception only evaluates events that already matched the original rule; it does not duplicate or replace 5706's detection logic.
- srcip 192.168.1.0/24 — Wazuh's built-in CIDR-range matching tag, scoping the exception precisely to the admin network.
- level=0 — suppresses the alert for matching events without disabling or weakening the underlying rule for any other source.

## Verification — Before / After Alert Volume

Source IP	Result Before Tuning	Result After Tuning
192.168.1.50 (admin range)	Rule 5706, level 6 — alert generated	Rule 100207, level 0 — silent, no alert
203.0.113.50 (external)	Rule 5706, level 6 — alert generated	Rule 5706, level 6 — alert generated (unchanged)

```
fara@ubuntuuserver:~$ docker exec -it single-node-wazuh.manager-1 /var/ossec/bin/wazuh-logtest
Starting wazuh-logtest v4.9.0
Type one log per line

Jul 13 19:05:00 ubuntuuserver sshd[99999]: Did not receive identification string from 192.168.1.50

**Phase 1: Completed pre-decoding.
 full event: 'Jul 13 19:05:00 ubuntuuserver sshd[99999]: Did not receive identification string from 192.1
68.1.50'
 timestamp: 'Jul 13 19:05:00'
 hostname: 'ubuntuuserver'
 program_name: 'sshd'

**Phase 2: Completed decoding.
 name: 'sshd'
 parent: 'sshd'
 srcip: '192.168.1.50'

**Phase 3: Completed filtering (rules).
 id: '100207'
 level: '0'
 description: 'sshd: insecure connection attempt (scan) - excluded admin range'
 groups: '['local']'
 firedtimes: '1'
 mail: 'False'
```

```
fara@ubuntuuserver:~$ docker exec -it single-node-wazuh.manager-1 /var/ossec/bin/wazuh-logtest
Starting wazuh-logtest v4.9.0
Type one log per line

Jul 13 19:05:00 ubuntuuserver sshd[99999]: Did not receive identification string from 203.0.113.50

**Phase 1: Completed pre-decoding.
 full event: 'Jul 13 19:05:00 ubuntuuserver sshd[99999]: Did not receive identification string from 203.0
.113.50'
 timestamp: 'Jul 13 19:05:00'
 hostname: 'ubuntuuserver'
 program_name: 'sshd'

**Phase 2: Completed decoding.
 name: 'sshd'
 parent: 'sshd'
 srcip: '203.0.113.50'

**Phase 3: Completed filtering (rules).
 id: '5706'
 level: '6'
 description: 'sshd: insecure connection attempt (scan).'
 groups: '['syslog', 'sshd', 'recon']'
 firedtimes: '1'
 gdpr: '['IV_35.7.d']'
 gpg13: '['4.12']'
 mail: 'False'
 mitre.id: '['T1021.004']'
 mitre.tactic: '['Lateral Movement']'
 mitre.technique: '['SSH']'
 nist_800_53: '['SI.4']'
 pci_dss: '['11.4']'
 tsc: '['CC6.1', 'CC6.8', 'CC7.2', 'CC7.3']'

**Alert to be generated.
```

This confirms the exception is precisely scoped: known, authorised internal scanning traffic is silenced, while detection for genuine external scanning activity remains fully intact and unaffected.

## Note on Task Specification

The task described rule 5706 as firing "on every SSH disconnect." Direct inspection of the ruleset confirmed rule 5706 specifically detects incomplete/scan-like connections (matching "Did not receive identification string from"), while a separate rule (5761) matches literal connection closures generically. Tuning was performed on rule 5706 as explicitly specified by ID.

## Conclusion

This exercise demonstrates the complete, auditable methodology required before any production detection exception is deployed: a clear statement of the rule's original behaviour, a quantified before/after comparison proving the change works as intended without over-suppressing, and a documented business justification. This is the standard of documentation expected for every tuning change made during a client engagement, precisely because undocumented tuning creates the kind of audit gap a security review or incident investigation cannot resolve after the fact.